

The CRA is a conformity case you must defend — not a test you pass.

Most teams hear "CRA" and reach for a penetration test and an SBOM generator. Both matter; neither is the point. The Act asks you to **build, organise and defend a body of evidence** that a product with digital elements is secure by design — for its whole supported life. That is an engineering, product and compliance program. It is what OXOT runs.

11 Dec 2027 no CE mark without it **11 Sep 2026** reporting enforceable **€15M** or 2.5% of turnover

10 yrs evidence retained

THE COMFORTABLE MISCONCEPTION

"CRA is just testing and SBOMs." It isn't.

WHAT TEAMS ASSUME

"Run a pen test, generate an SBOM, tick the box, ship."

WHAT THE REGULATION REQUIRES

A **defensible technical file**: risk assessment, secure-development evidence, per-requirement mapping, and vulnerability-handling processes that run for the whole support period — **assembled, organised and maintained**, not produced once and filed.

THE IEC 62443 FOUNDATION

Two disciplines — both new to most product teams

IEC 62443-4-1 · SECURE DEVELOPMENT

The **process** evidence — how the product is designed, built, tested and maintained. Unfamiliar ground for teams that ship features, not conformity artifacts.

IEC 62443-4-2 · COMPONENT REQUIREMENTS

The **technical** validation — does each component meet its security-level requirements, with evidence to prove it.

Together they build the body of evidence a Module A self-attestation for **ICS / IACS** actually needs. Few engineering teams have assembled one before — and the CRA gives them a deadline to learn.

WHERE RESPONSIBILITY ACTUALLY LANDS

It doesn't stop at your own code

OEMS & MANUFACTURERS

You inherit the security posture of every supplier component you integrate. Their gaps become **your** non-conformities — and you must evidence the whole assembly.

IMPORTERS, RESELLERS & DISTRIBUTORS

You carry obligations too — verifying conformity, holding documentation, and reporting. Placing a non-conforming product on the market is **your** exposure.

Module A looks simple. Getting it wrong is not.

MARKET LOCKOUT

No CE mark, no EU sale — for every affected product line.

FINANCIAL PENALTY

Up to €15M or 2.5% of global annual turnover.

PORTFOLIO SCRUTINY

One flawed attestation invites a look at everything else you ship.

OXOT leads the whole journey to the CE mark.

Not bits and bytes of testing bought here and there — a strategy, with intent and experience, that leads your engineering, product, commercial and compliance teams through conformity. We organise the work programmatically, focus effort where it changes the outcome, and produce the artifacts that hold up under review.

THE ENGAGEMENT · THREE PHASES, REPEATABLE PER PRODUCT

Assess → Test & validate → Build & certify-prep

1 ASSESS

Classify the product, threat-model the system, set target security levels, and find the gaps — so effort is prioritised **before** an engineering hour is spent.

2 TEST & VALIDATE

Evidence the requirements inside OT-safe guardrails — formal verification & validation against CRA requirements, not opinion. Findings ranked, not just listed.

3 BUILD & CERTIFY-PREP

Close the gaps, stand up the vulnerability-handling processes, and compile the Annex VII technical file — a defensible **Module A self-attestation**.

WHY THE INVESTMENT IN OXOT PAYS

Experience that turns a regulatory burden into a repeatable program

- › **Programmatic, not piecemeal** — one disciplined method that runs the same way across 1 product or 100.
- › **Artifacts, organised** — the processes, records and evidence a Notified Body or market-surveillance authority expects, produced and kept in order.
- › **OT / ICS-native** — deep IEC 62443 fluency for the products where the CRA bites hardest.
- › **Efficient by design** — ALARP-reasoned scope puts resources where they change conformity, and nowhere else.
- › **Cross-functional leadership** — we align engineering, product, commercial and compliance around one defensible plan.
- › **Evidence that holds** — built to survive third-party review, not just satisfy an internal checkbox.

THE OUTCOME

A defensible path to the CE mark — the compiled Annex VII technical file, the working vulnerability-handling processes behind it, and a Module A self-attestation your teams can stand behind when market surveillance asks.

Start with a two-week readiness triage.

Your classification, your top gaps, and a costed path to conformity — before the deadline sets the timeline for you.

Talk to OXOT →

jim.mckenney@oxot.nl

The statutes behind the claims

What pages 1–2 rest on — the product-specific obligations of **Reg (EU) 2024/2847**, condensed. This is the material the OXOT program organises, evidences and defends.

01 · SCOPE

What products are covered

The CRA applies to any **"product with digital elements" (PDE)** — hardware or software that connects, directly or indirectly, to a device or network. Scope is assessed **per unit**, and the date each unit is first placed on the EU market is legally determinative.

EXPLICITLY IN SCOPE

Industrial control units · SCADA / ICS components · IoT devices · routers · firewalls · smart-meter gateways · standalone software. **If it has programmable logic and it connects, it is almost certainly a PDE.**

02 · CLASSIFICATION

Product classes & assessment route (Annex III / IV)

CLASS	EXAMPLES	ASSESSMENT ROUTE
Default	Most consumer IoT, basic software	Self-assessment (Module A)
Important I	OS, browsers, VPNs, routers, switches, SIEM, MCUs/FPGAs with security functions	Module A with a harmonized standard; else Module B+C or H
Important II	Firewalls, IDS/IPS, hypervisors, container isolation layers	Always via a Notified Body
Critical (Annex IV)	Smart-meter gateways, HSMS, secure elements	Always via a Notified Body

Most industrial products land in **Default** or **Important I** — the self-assessment route, *provided the technical substantiation holds*. That proviso is the entire game.

03 · ESSENTIAL REQUIREMENTS

The 13 product security properties (Annex I, §1)

- 01

No known exploitable vulnerabilities
- 02

Security by design
- 03

Secure by default
- 04

Confidentiality — encryption
- 05

Integrity of data & code
- 06

Availability of essential functions
- 07

Access control & authentication
- 08

Data minimisation
- 09

Minimal attack surface
- 10

Authenticated, verified updates
- 11

Resilience — resist & recover
- 12

Security logging
- 13

Third-party component management

Each must be addressed in the risk assessment — applicable, partially applicable, or not, **with rationale**. That mapping is what a self-attestation stands or falls on.

04 · VULNERABILITY HANDLING

Lifecycle process obligations (Annex I, §2)

Unlike the product properties, these are **processes** the manufacturer must operate throughout the support period — not one-off features. This is where "testing and SBOMs" ends and program management begins.

- › **Remediate without delay** — identify, document and fix as discovered.
- › **Maintain an SBOM** — machine-readable (SPDX / CycloneDX).
- › **Free security updates** for the support period — min. 5 years.
- › **Publish a CVD contact** — a disclosure policy researchers can use.

REPORT EXPLOITED VULNERABILITIES TO ENISA — ENFORCEABLE FROM 11 SEP 2026		
24 h Initial early warning	72 h Technical notification	14 d Final report, post-remediation

05 · PRE-RELEASE DOCUMENTATION

The Technical File (Annex VII)

Compiled before CE marking, retained afterwards — the evidentiary backbone of the declaration, and the single artifact the whole OXOT engagement builds toward.

- › **Product description** & intended use.
- › **Risk assessment** — threat model, methodology & versions.
- › **SDL evidence** — IEC 62443-4-1 / ISO 27001 aids presumption.
- › **Security test results**, incl. penetration-testing evidence.
- › **SBOM** — vulnerability-screened; an unresolved component CVE is a direct violation.
- › **Connection audit** — every port and connection individually justified.
- › **Declared End-of-Life date** — min. 5 years; capped by key dependencies.
- › **EU Declaration of Conformity** (Annex V) — retained 10 years.

06 · USER INFORMATION · 07 · DEADLINES

What users must be given & when it bites

ANNEX II Intended use & cybersecurity properties · how to configure the security features · the declared End-of-Life date · how to report vulnerabilities · **12 months' notice** before the final security update.

11 Sep 2026 ENISA vulnerability-reporting obligations become enforceable.	11 Dec 2027 Full enforcement — no CE marking, no EU market access.
--	---

WHY THIS ANNEX EXISTS
This is the real scope of a "simple" Module A self-attestation — properties, processes, documentation and deadlines that must hold together as one defensible case. It is why a pen test and an SBOM don't reach the CE mark, and why OXOT organises the whole journey.

This reference summarises Regulation (EU) 2024/2847 for orientation and is not legal advice. Classification and applicability must be confirmed per product against the current regulatory text and any published harmonised standards.